

Security Architecture

Firewalls, IAM, encryption, and compliance

Document ID: EA-SEC-006

This document is the property of ArchiSurance B.V. and contains confidential information. Unauthorized reproduction or distribution is prohibited. For questions contact the Enterprise Architecture team at ea-team@archisurance.example.com.

Document Version History

Ver.	Date	Author	Description
0.1	2024-01-15	J. van den Berg	Initial draft
0.5	2024-03-22	M. de Vries	Peer review incorporated
1.0	2024-06-10	P. Jansen	Approved by Architecture Board
1.5	2024-11-04	J. van den Berg	Updated for Q4 changes
2.0	2025-02-18	M. de Vries	Annual revision
2.1	2025-04-01	P. Jansen	Minor corrections

Table of Contents

1 Introduction 1

2 Perimeter Security 2

3 Identity and Access Management 3

4 Data Encryption 4

5 Security Monitoring 5

6 Compliance Requirements 6

7 Security Architecture Decisions 7

8 Appendices 8

1. Introduction

This document describes the security architecture of ArchiSurance, covering perimeter defenses, identity management, data protection, and compliance with regulatory frameworks. The security architecture is aligned with the strategic goal to Zero Data Breaches by 2026 championed by the CISO and the Chief Risk Officer.

For the network topology referenced in this document, see the Network Architecture document (EA-NET-011). Infrastructure details are in the Infrastructure Design Document (EA-INFRA-003).

Cross-functional workshops held in January and March 2025 helped refine the scope and integration points. A proof-of-concept was conducted over a four-week period, involving representatives from the Claims Department, IT Operations, and the Data Analytics Team to validate the technical feasibility. The project governance structure includes a steering committee meeting monthly, a working group meeting weekly, and daily stand-ups during active development sprints. The data retention policy mandates that transactional records are kept for seven years in online storage and archived to cold storage thereafter, with the ability to retrieve archived records within twenty-four hours upon regulatory request. The design considers both current-state constraints and target-state aspirations as documented in the strategic roadmap. Key performance indicators for the initiative include transaction throughput, error rate, mean time to detection, mean time to recovery, and user satisfaction scores collected through quarterly surveys. Change management activities include stakeholder communication, training sessions, and documentation updates. An accessibility audit was conducted by an external specialist in January 2025 to ensure that all user-facing components meet WCAG 2.1 Level AA standards, with remediation items tracked in the product backlog. The platform engineering team provides a standardized deployment template that all application teams are required to use, ensuring consistency in logging, health checks, and resource limits. Regression test suites are maintained by the QA team and executed automatically on every merge to the main branch via the CI/CD pipeline. The architectural principles that guide this work include separation of concerns, loose coupling between components, preference for open standards, and the ability to scale horizontally under peak load conditions such as end-of-year policy renewals. Lessons learned from the pilot phase have been incorporated into the current design iteration. The observability strategy follows the three pillars model: structured logs shipped to Elasticsearch, distributed traces collected via OpenTelemetry, and metrics scraped by Prometheus; all three are unified in Grafana dashboards. Stakeholders across multiple departments have contributed requirements for this workstream. Feedback from the user acceptance testing phase indicated that the new interface reduced the average task completion time by approximately thirty percent compared to the legacy system, though some users requested additional keyboard shortcuts for power-user workflows. Capacity planning exercises revealed that the current infrastructure can sustain projected growth for the next twelve months, after which additional compute and storage resources will be required. A dedicated Slack channel was established for real-time coordination between development, operations, and security teams during the rollout period. The business process documentation follows the BPMN 2.0 standard, with process models maintained in the Signavio process modeling tool and linked to the ArchiMate model elements in Sparx EA. The migration strategy follows a strangler-fig pattern, where new functionality is built in the target platform while legacy features are gradually redirected; this approach minimizes disruption to active users and allows incremental validation of the new implementation. Monitoring and alerting are integrated with the central observability stack based on Prometheus and Grafana. In the context of insurance operations, peak load occurs during natural disaster events when claim submissions can spike by up to ten times the normal rate; the auto-scaling configuration accounts for this burst pattern. Deployment windows are scheduled every Tuesday and Thursday between 06:00 and 08:00 CET, with emergency deployments requiring approval from both the IT Service Manager and the on-call engineer. Integration testing spans three environments: development, staging, and pre-production. Dependencies on third-party services were documented and risk-assessed, with fallback mechanisms defined for each critical integration point. The total cost of ownership analysis, prepared by the Finance Department in collaboration with IT, indicated a payback period of approximately eighteen months assuming current utilization rates. The architecture review confirmed that the proposed solution aligns with the TOGAF Architecture Development Method phases used by ArchiSurance, specifically phases B through D covering Business, Information Systems, and Technology Architecture.

Capacity planning exercises revealed that the current infrastructure can sustain projected growth for the next twelve months, after which additional compute and storage resources will be required. The API design guidelines specify that all REST endpoints must support content negotiation, return standard HTTP status codes, include correlation identifiers in response headers, and provide machine-readable error bodies in RFC 7807 format. Post-implementation review

sessions are scheduled for thirty and ninety days after go-live to capture lessons learned and identify optimization opportunities. Monitoring and alerting are integrated with the central observability stack based on Prometheus and Grafana. The security architecture design has been a critical area of focus for ArchiSurance since the digital transformation initiative began in 2023. The enterprise technology radar, published semi-annually by the CTO's office, classifies technologies as Adopt, Trial, Assess, or Hold; the technologies used in this area are all currently in the Adopt or Trial rings. Implementation follows an iterative approach, with quarterly milestones aligned to the overall program timeline. Dependencies on third-party services were documented and risk-assessed, with fallback mechanisms defined for each critical integration point. The incident management process defines four severity levels, with Severity 1 incidents requiring a response within fifteen minutes and a post-incident review within five business days.

Business continuity considerations were incorporated from the outset, with the DR Recovery Node in the secondary data center providing failover capacity; the most recent failover test was conducted in October 2024 and achieved recovery within the target RTO of one hour. Stakeholders across multiple departments have contributed requirements for this workstream. Collaboration with the vendor support team has been essential during the implementation phase; weekly technical syncs ensure that configuration changes are validated against the vendor's reference architecture before being applied to the production environment. The security architecture design has been a critical area of focus for ArchiSurance since the digital transformation initiative began in 2023. The architecture team conducted a threat modeling exercise using the STRIDE framework, identifying potential spoofing, tampering, and information disclosure risks; mitigations for each threat were documented and tracked in the security risk register. Regression test suites are maintained by the QA team and executed automatically on every merge to the main branch via the CI/CD pipeline. The initiative is tracked in the enterprise PMO tool with bi-weekly status updates to the steering committee. The solution was designed to be modular, allowing individual components to be upgraded or replaced without affecting the overall system availability or data integrity. The network team conducted a bandwidth utilization study in February 2025, confirming that inter-datacenter traffic remains below sixty percent of the available WAN capacity under normal operating conditions.

The operational acceptance criteria include automated smoke tests, performance baselines, runbook completeness, and sign-off from both the IT Service Manager and the business process owner. Technical debt in this area was cataloged during a dedicated sprint in Q3 2024; the resulting backlog of forty-seven items has been prioritized by business impact and is being addressed alongside feature development. A chaos engineering program was introduced in Q1 2025, starting with controlled fault injection in the staging environment to validate the resilience of the system against network partitions and dependency failures. Budget allocation was approved as part of the annual IT investment portfolio review conducted in November 2024. Automated deployment pipelines leverage the CI/CD infrastructure described in the platform engineering documentation. An internal audit in March 2025 confirmed that the controls implemented for this area meet the requirements of the enterprise risk management framework. Lessons learned from the pilot phase have been incorporated into the current design iteration. The design considers both current-state constraints and target-state aspirations as documented in the strategic roadmap. Dependencies on third-party services were documented and risk-assessed, with fallback mechanisms defined for each critical integration point.

2. Perimeter Security

The perimeter is protected by the PA Firewall, a next-generation firewall deployed at the boundary between the the DMZ and the Corporate Ethernet. The Load Balancer F5 sits in the DMZ and terminates TLS connections before forwarding traffic to the API Gateway.

The Content Delivery Network serves static assets from edge locations and includes DDoS mitigation capabilities. All inbound traffic passes through WAF rules configured on the F5 Big-IP before reaching application servers.

The migration strategy follows a strangler-fig pattern, where new functionality is built in the target platform while legacy features are gradually redirected; this approach minimizes disruption to active users and allows incremental validation of the new implementation. The operational support model is defined in the Operational Runbook and includes on-call rotation and escalation procedures. Application health is assessed using a synthetic monitoring approach, where automated scripts simulate real user journeys every five minutes and report availability from three geographically distributed probe locations. A formal lessons-learned workshop is held at the end of each quarter, with outcomes published to the internal wiki and action items assigned to specific team members with target completion dates. Budget

allocation was approved as part of the annual IT investment portfolio review conducted in November 2024. Documentation standards require that all architecture decisions are recorded as Architecture Decision Records using the ADR format proposed by Michael Nygard, stored alongside the codebase in the version control system. Data privacy impact assessment was filed with the Data Protection Officer in Q1 2025. The operational acceptance criteria include automated smoke tests, performance baselines, runbook completeness, and sign-off from both the IT Service Manager and the business process owner. A dedicated Slack channel was established for real-time coordination between development, operations, and security teams during the rollout period. Service-level indicators are collected continuously and aggregated into dashboards visible to both technical teams and business stakeholders. From a historical perspective, ArchiSurance first recognized the need for modernization in this area following an internal efficiency review conducted in late 2022, which highlighted significant manual effort and process duplication across regional offices. The enterprise backup strategy uses a 3-2-1 approach: three copies of data, on two different media types, with one copy stored offsite at the secondary data center in Rotterdam. The architectural principles that guide this work include separation of concerns, loose coupling between components, preference for open standards, and the ability to scale horizontally under peak load conditions such as end-of-year policy renewals. The API design guidelines specify that all REST endpoints must support content negotiation, return standard HTTP status codes, include correlation identifiers in response headers, and provide machine-readable error bodies in RFC 7807 format. Scalability testing performed in the staging environment confirmed that the system handles a three-times-peak load without degradation, providing sufficient headroom for seasonal demand fluctuations. The data classification exercise, completed in Q4 2024, assigned sensitivity labels to all data objects, informing encryption, access control, and retention policies. Dependencies on third-party services were documented and risk-assessed, with fallback mechanisms defined for each critical integration point. Risk mitigation strategies include regular checkpoint reviews, automated regression testing, and staged rollout procedures. The information security team requires that all new systems undergo a penetration test before production deployment, with findings above medium severity remediated prior to go-live approval. External consultants from Deloitte provided an independent assessment of the architecture in late 2024. Change management activities include stakeholder communication, training sessions, and documentation updates. Interoperability with partner systems is achieved through the Partner Integration Hub, which exposes a curated subset of the internal API surface with additional rate limiting, schema validation, and audit logging applied at the gateway layer. The observability strategy follows the three pillars model: structured logs shipped to Elasticsearch, distributed traces collected via OpenTelemetry, and metrics scraped by Prometheus; all three are unified in Grafana dashboards. The business process documentation follows the BPMN 2.0 standard, with process models maintained in the Signavio process modeling tool and linked to the ArchiMate model elements in Sparx EA. Cross-functional workshops held in January and March 2025 helped refine the scope and integration points. The incident management process defines four severity levels, with Severity 1 incidents requiring a response within fifteen minutes and a post-incident review within five business days. The enterprise identity provider federates with the national eHerkenning system for business-to-government interactions and with DigiD for customer-facing authentication on the self-service portal. Performance benchmarks are captured in the enterprise monitoring framework and reported on a monthly basis to leadership.

An accessibility audit was conducted by an external specialist in January 2025 to ensure that all user-facing components meet WCAG 2.1 Level AA standards, with remediation items tracked in the product backlog. From a historical perspective, ArchiSurance first recognized the need for modernization in this area following an internal efficiency review conducted in late 2022, which highlighted significant manual effort and process duplication across regional offices. The enterprise technology radar, published semi-annually by the CTO's office, classifies technologies as Adopt, Trial, Assess, or Hold; the technologies used in this area are all currently in the Adopt or Trial rings. Integration testing spans three environments: development, staging, and pre-production. ArchiSurance participates in an industry-wide information sharing and analysis center for insurance companies, contributing anonymized threat intelligence data and receiving early warnings about sector-specific attack patterns. The solution leverages event-driven patterns wherever possible, with Apache Kafka providing durable, ordered event streams that decouple producers from consumers and enable replay for debugging and reprocessing scenarios. The solution was designed to be modular, allowing individual components to be upgraded or replaced without affecting the overall system availability or data integrity. Scalability testing performed in the staging environment confirmed that the system handles a three-times-peak load without degradation, providing sufficient headroom for seasonal demand fluctuations. Regression test suites are maintained by the QA team and executed automatically on every merge to the main branch via the CI/CD pipeline.

An accessibility audit was conducted by an external specialist in January 2025 to ensure that all user-facing components

meet WCAG 2.1 Level AA standards, with remediation items tracked in the product backlog. Service-level indicators are collected continuously and aggregated into dashboards visible to both technical teams and business stakeholders. Integration testing spans three environments: development, staging, and pre-production. Lessons learned from the pilot phase have been incorporated into the current design iteration. During the initial assessment phase, the team identified several areas where the existing architecture fell short of the target-state requirements defined in the enterprise roadmap. The enterprise architecture repository in Sparx EA is the authoritative source for all model elements; any changes to this document must be reflected there within five business days. The design considers both current-state constraints and target-state aspirations as documented in the strategic roadmap. A comprehensive training program was developed for end users, including online modules, instructor-led sessions, and a sandbox environment for hands-on practice. The architectural principles that guide this work include separation of concerns, loose coupling between components, preference for open standards, and the ability to scale horizontally under peak load conditions such as end-of-year policy renewals.

Automated deployment pipelines leverage the CI/CD infrastructure described in the platform engineering documentation. Lessons learned from the pilot phase have been incorporated into the current design iteration. Post-implementation review sessions are scheduled for thirty and ninety days after go-live to capture lessons learned and identify optimization opportunities. The solution leverages event-driven patterns wherever possible, with Apache Kafka providing durable, ordered event streams that decouple producers from consumers and enable replay for debugging and reprocessing scenarios. The migration strategy follows a strangler-fig pattern, where new functionality is built in the target platform while legacy features are gradually redirected; this approach minimizes disruption to active users and allows incremental validation of the new implementation. In the context of insurance operations, peak load occurs during natural disaster events when claim submissions can spike by up to ten times the normal rate; the auto-scaling configuration accounts for this burst pattern. Cross-functional workshops held in January and March 2025 helped refine the scope and integration points. The enterprise architecture repository in Sparx EA is the authoritative source for all model elements; any changes to this document must be reflected there within five business days. Service-level indicators are collected continuously and aggregated into dashboards visible to both technical teams and business stakeholders.

3. Identity and Access Management

The IAM platform provides centralized authentication and authorization for all ArchiSurance systems. It exposes the Authentication API for single sign-on (SSO) and multi-factor authentication (MFA). All authentication events are logged in the Audit Log data object.

Role-based access control (RBAC) is enforced across all application components. The Customer Identity Verification process described in the CRM Business Process Description (EA-BIZ-004) uses the same IAM platform for KYC checks.

Key performance indicators for the initiative include transaction throughput, error rate, mean time to detection, mean time to recovery, and user satisfaction scores collected through quarterly surveys. Scalability testing performed in the staging environment confirmed that the system handles a three-times-peak load without degradation, providing sufficient headroom for seasonal demand fluctuations. The business process documentation follows the BPMN 2.0 standard, with process models maintained in the Signavio process modeling tool and linked to the ArchiMate model elements in Sparx EA. Deployment windows are scheduled every Tuesday and Thursday between 06:00 and 08:00 CET, with emergency deployments requiring approval from both the IT Service Manager and the on-call engineer. Post-implementation review sessions are scheduled for thirty and ninety days after go-live to capture lessons learned and identify optimization opportunities. External consultants from Deloitte provided an independent assessment of the architecture in late 2024. An accessibility audit was conducted by an external specialist in January 2025 to ensure that all user-facing components meet WCAG 2.1 Level AA standards, with remediation items tracked in the product backlog. The initiative is tracked in the enterprise PMO tool with bi-weekly status updates to the steering committee. The vendor selection process followed the procurement guidelines established by the CFO's office. Integration testing spans three environments: development, staging, and pre-production. Stakeholders across multiple departments have contributed requirements for this workstream. Budget allocation was approved as part of the annual IT investment portfolio review conducted in November 2024. The project governance structure includes a steering committee meeting monthly, a working group meeting weekly, and daily stand-ups during active development sprints. Data privacy impact assessment was filed with

the Data Protection Officer in Q1 2025. Capacity planning exercises revealed that the current infrastructure can sustain projected growth for the next twelve months, after which additional compute and storage resources will be required. The enterprise backup strategy uses a 3-2-1 approach: three copies of data, on two different media types, with one copy stored offsite at the secondary data center in Rotterdam. Feedback from the user acceptance testing phase indicated that the new interface reduced the average task completion time by approximately thirty percent compared to the legacy system, though some users requested additional keyboard shortcuts for power-user workflows. The enterprise data model, maintained by the Data Architecture team, defines canonical schemas for all shared data objects; integrating systems are expected to conform to these schemas or implement transformation layers that map proprietary formats to the canonical model.

Performance benchmarks are captured in the enterprise monitoring framework and reported on a monthly basis to leadership. The enterprise identity provider federates with the national eHerkenning system for business-to-government interactions and with DigiD for customer-facing authentication on the self-service portal. Application health is assessed using a synthetic monitoring approach, where automated scripts simulate real user journeys every five minutes and report availability from three geographically distributed probe locations. Service-level indicators are collected continuously and aggregated into dashboards visible to both technical teams and business stakeholders. The operational support model is defined in the Operational Runbook and includes on-call rotation and escalation procedures. The architecture decisions were reviewed and approved by the Architecture Review Board in Q2 2024. Change management activities include stakeholder communication, training sessions, and documentation updates. Capacity planning exercises revealed that the current infrastructure can sustain projected growth for the next twelve months, after which additional compute and storage resources will be required. The team uses a definition of done that includes code review by at least two peers, passing CI pipeline, updated architecture diagrams, and entry in the change log maintained by the Release Manager. Data privacy impact assessment was filed with the Data Protection Officer in Q1 2025.

Lessons learned from the pilot phase have been incorporated into the current design iteration. Collaboration with the vendor support team has been essential during the implementation phase; weekly technical syncs ensure that configuration changes are validated against the vendor's reference architecture before being applied to the production environment. Integration testing spans three environments: development, staging, and pre-production. The design considers both current-state constraints and target-state aspirations as documented in the strategic roadmap. An accessibility audit was conducted by an external specialist in January 2025 to ensure that all user-facing components meet WCAG 2.1 Level AA standards, with remediation items tracked in the product backlog. Cross-functional workshops held in January and March 2025 helped refine the scope and integration points. The Architecture Review Board convened a special session in February 2025 to evaluate the implications of the proposed changes on downstream systems and business processes. Documentation standards require that all architecture decisions are recorded as Architecture Decision Records using the ADR format proposed by Michael Nygard, stored alongside the codebase in the version control system. The migration strategy follows a strangler-fig pattern, where new functionality is built in the target platform while legacy features are gradually redirected; this approach minimizes disruption to active users and allows incremental validation of the new implementation. The architecture review confirmed that the proposed solution aligns with the TOGAF Architecture Development Method phases used by ArchiSurance, specifically phases B through D covering Business, Information Systems, and Technology Architecture.

Implementation follows an iterative approach, with quarterly milestones aligned to the overall program timeline. The architecture team conducted a threat modeling exercise using the STRIDE framework, identifying potential spoofing, tampering, and information disclosure risks; mitigations for each threat were documented and tracked in the security risk register. The non-functional requirements specify a maximum end-to-end latency of five hundred milliseconds at the ninety-ninth percentile, measured under a sustained load of one thousand concurrent users. A proof-of-concept was conducted over a four-week period, involving representatives from the Claims Department, IT Operations, and the Data Analytics Team to validate the technical feasibility. The solution leverages event-driven patterns wherever possible, with Apache Kafka providing durable, ordered event streams that decouple producers from consumers and enable replay for debugging and reprocessing scenarios. A comprehensive training program was developed for end users, including online modules, instructor-led sessions, and a sandbox environment for hands-on practice. The total cost of ownership analysis, prepared by the Finance Department in collaboration with IT, indicated a payback period of approximately eighteen months assuming current utilization rates. An internal audit in March 2025 confirmed that the controls implemented for this area meet the requirements of the enterprise risk management framework. A formal

lessons-learned workshop is held at the end of each quarter, with outcomes published to the internal wiki and action items assigned to specific team members with target completion dates. Scalability testing performed in the staging environment confirmed that the system handles a three-times-peak load without degradation, providing sufficient headroom for seasonal demand fluctuations.

4. Data Encryption

All data at rest is encrypted using AES-256 with keys managed by the HSM Appliance. The Secrets Management Service and Certificate Management Service both rely on the HSM for cryptographic operations. Database-level encryption is enabled on Postgres (transparent data encryption) and Oracle Database 19c (Oracle Advanced Security).

All data in transit is protected by TLS 1.3. The requirement for Data Encryption at Rest and in Transit is driven by the GDPR Compliance and PCI-DSS Level 1 Certification requirements.

The enterprise backup strategy uses a 3-2-1 approach: three copies of data, on two different media types, with one copy stored offsite at the secondary data center in Rotterdam. The incident management process defines four severity levels, with Severity 1 incidents requiring a response within fifteen minutes and a post-incident review within five business days. Post-implementation review sessions are scheduled for thirty and ninety days after go-live to capture lessons learned and identify optimization opportunities. A dedicated Slack channel was established for real-time coordination between development, operations, and security teams during the rollout period. The architecture review confirmed that the proposed solution aligns with the TOGAF Architecture Development Method phases used by ArchiSurance, specifically phases B through D covering Business, Information Systems, and Technology Architecture. The enterprise technology radar, published semi-annually by the CTO's office, classifies technologies as Adopt, Trial, Assess, or Hold; the technologies used in this area are all currently in the Adopt or Trial rings. Deployment windows are scheduled every Tuesday and Thursday between 06:00 and 08:00 CET, with emergency deployments requiring approval from both the IT Service Manager and the on-call engineer. Capacity forecasting models project a twenty-five percent year-over-year increase in data volume, driven primarily by the digitization of paper-based processes and the expansion of the broker channel. Budget allocation was approved as part of the annual IT investment portfolio review conducted in November 2024. Lessons learned from the pilot phase have been incorporated into the current design iteration. An internal audit in March 2025 confirmed that the controls implemented for this area meet the requirements of the enterprise risk management framework. Interoperability with partner systems is achieved through the Partner Integration Hub, which exposes a curated subset of the internal API surface with additional rate limiting, schema validation, and audit logging applied at the gateway layer. The vendor selection process followed the procurement guidelines established by the CFO's office. Technical debt in this area was cataloged during a dedicated sprint in Q3 2024; the resulting backlog of forty-seven items has been prioritized by business impact and is being addressed alongside feature development. Capacity planning exercises revealed that the current infrastructure can sustain projected growth for the next twelve months, after which additional compute and storage resources will be required. Cost allocation for shared infrastructure follows a chargeback model based on resource consumption metrics, with monthly reports sent to each business unit for transparency and accountability. The architecture decisions were reviewed and approved by the Architecture Review Board in Q2 2024. The transition plan was developed in alignment with the enterprise change management framework, incorporating staged rollouts, parallel-run periods, and defined go/no-go criteria at each milestone. The migration strategy follows a strangler-fig pattern, where new functionality is built in the target platform while legacy features are gradually redirected; this approach minimizes disruption to active users and allows incremental validation of the new implementation. The solution leverages event-driven patterns wherever possible, with Apache Kafka providing durable, ordered event streams that decouple producers from consumers and enable replay for debugging and reprocessing scenarios. A proof-of-concept was conducted over a four-week period, involving representatives from the Claims Department, IT Operations, and the Data Analytics Team to validate the technical feasibility. The operational acceptance criteria include automated smoke tests, performance baselines, runbook completeness, and sign-off from both the IT Service Manager and the business process owner. The data classification exercise, completed in Q4 2024, assigned sensitivity labels to all data objects, informing encryption, access control, and retention policies. A formal lessons-learned workshop is held at the end of each quarter, with outcomes published to the internal wiki and action items assigned to specific team members with target completion dates. The development team follows trunk-based development with short-lived feature branches, automated linting, and a code coverage threshold of eighty percent enforced by the CI pipeline. An accessibility audit was conducted by an external specialist in January 2025 to ensure

that all user-facing components meet WCAG 2.1 Level AA standards, with remediation items tracked in the product backlog. The platform engineering team provides a standardized deployment template that all application teams are required to use, ensuring consistency in logging, health checks, and resource limits.

The architectural principles that guide this work include separation of concerns, loose coupling between components, preference for open standards, and the ability to scale horizontally under peak load conditions such as end-of-year policy renewals. Interoperability with partner systems is achieved through the Partner Integration Hub, which exposes a curated subset of the internal API surface with additional rate limiting, schema validation, and audit logging applied at the gateway layer. The data classification exercise, completed in Q4 2024, assigned sensitivity labels to all data objects, informing encryption, access control, and retention policies. The total cost of ownership analysis, prepared by the Finance Department in collaboration with IT, indicated a payback period of approximately eighteen months assuming current utilization rates. Implementation follows an iterative approach, with quarterly milestones aligned to the overall program timeline. From a historical perspective, ArchiSurance first recognized the need for modernization in this area following an internal efficiency review conducted in late 2022, which highlighted significant manual effort and process duplication across regional offices. The project governance structure includes a steering committee meeting monthly, a working group meeting weekly, and daily stand-ups during active development sprints. Application health is assessed using a synthetic monitoring approach, where automated scripts simulate real user journeys every five minutes and report availability from three geographically distributed probe locations. An internal audit in March 2025 confirmed that the controls implemented for this area meet the requirements of the enterprise risk management framework. Budget allocation was approved as part of the annual IT investment portfolio review conducted in November 2024.

The information security team requires that all new systems undergo a penetration test before production deployment, with findings above medium severity remediated prior to go-live approval. The network team conducted a bandwidth utilization study in February 2025, confirming that inter-datacenter traffic remains below sixty percent of the available WAN capacity under normal operating conditions. The solution leverages event-driven patterns wherever possible, with Apache Kafka providing durable, ordered event streams that decouple producers from consumers and enable replay for debugging and reprocessing scenarios. The enterprise identity provider federates with the national eHerkenning system for business-to-government interactions and with DigiD for customer-facing authentication on the self-service portal. Dependencies on third-party services were documented and risk-assessed, with fallback mechanisms defined for each critical integration point. During the initial assessment phase, the team identified several areas where the existing architecture fell short of the target-state requirements defined in the enterprise roadmap. External consultants from Deloitte provided an independent assessment of the architecture in late 2024. Post-implementation review sessions are scheduled for thirty and ninety days after go-live to capture lessons learned and identify optimization opportunities. The operational acceptance criteria include automated smoke tests, performance baselines, runbook completeness, and sign-off from both the IT Service Manager and the business process owner. The data classification exercise, completed in Q4 2024, assigned sensitivity labels to all data objects, informing encryption, access control, and retention policies.

ArchiSurance participates in an industry-wide information sharing and analysis center for insurance companies, contributing anonymized threat intelligence data and receiving early warnings about sector-specific attack patterns. Budget allocation was approved as part of the annual IT investment portfolio review conducted in November 2024. The project governance structure includes a steering committee meeting monthly, a working group meeting weekly, and daily stand-ups during active development sprints. The vendor risk assessment framework evaluates suppliers across five dimensions: financial stability, technology roadmap alignment, support quality, security posture, and contractual flexibility. Interoperability with partner systems is achieved through the Partner Integration Hub, which exposes a curated subset of the internal API surface with additional rate limiting, schema validation, and audit logging applied at the gateway layer. The solution leverages event-driven patterns wherever possible, with Apache Kafka providing durable, ordered event streams that decouple producers from consumers and enable replay for debugging and reprocessing scenarios. A proof-of-concept was conducted over a four-week period, involving representatives from the Claims Department, IT Operations, and the Data Analytics Team to validate the technical feasibility. The configuration management database maintains a record of all IT assets, including hardware serial numbers, software license keys, patch levels, and relationships between configuration items. The operational acceptance criteria include automated smoke tests, performance baselines, runbook completeness, and sign-off from both the IT Service Manager and the business process owner. From a historical perspective, ArchiSurance first recognized the need for modernization in this area following an internal efficiency review conducted in late 2022, which highlighted significant manual effort and process duplication across regional offices.

5. Security Monitoring

Security events are collected by the Log Aggregation Service, running on the Log Aggregation Node and the Monitoring Server. The search engine cluster indexes all security logs for real-time threat detection and forensic analysis.

Implementation follows an iterative approach, with quarterly milestones aligned to the overall program timeline. The solution leverages event-driven patterns wherever possible, with Apache Kafka providing durable, ordered event streams that decouple producers from consumers and enable replay for debugging and reprocessing scenarios. A formal lessons-learned workshop is held at the end of each quarter, with outcomes published to the internal wiki and action items assigned to specific team members with target completion dates. Cost allocation for shared infrastructure follows a chargeback model based on resource consumption metrics, with monthly reports sent to each business unit for transparency and accountability. Automated deployment pipelines leverage the CI/CD infrastructure described in the platform engineering documentation. The configuration management database maintains a record of all IT assets, including hardware serial numbers, software license keys, patch levels, and relationships between configuration items. The transition plan was developed in alignment with the enterprise change management framework, incorporating staged rollouts, parallel-run periods, and defined go/no-go criteria at each milestone. The architecture review confirmed that the proposed solution aligns with the TOGAF Architecture Development Method phases used by ArchiSurance, specifically phases B through D covering Business, Information Systems, and Technology Architecture. The API design guidelines specify that all REST endpoints must support content negotiation, return standard HTTP status codes, include correlation identifiers in response headers, and provide machine-readable error bodies in RFC 7807 format. Regression test suites are maintained by the QA team and executed automatically on every merge to the main branch via the CI/CD pipeline. A proof-of-concept was conducted over a four-week period, involving representatives from the Claims Department, IT Operations, and the Data Analytics Team to validate the technical feasibility. A chaos engineering program was introduced in Q1 2025, starting with controlled fault injection in the staging environment to validate the resilience of the system against network partitions and dependency failures. Risk mitigation strategies include regular checkpoint reviews, automated regression testing, and staged rollout procedures. Lessons learned from the pilot phase have been incorporated into the current design iteration. Budget allocation was approved as part of the annual IT investment portfolio review conducted in November 2024. Dependencies on third-party services were documented and risk-assessed, with fallback mechanisms defined for each critical integration point. The project governance structure includes a steering committee meeting monthly, a working group meeting weekly, and daily stand-ups during active development sprints. Stakeholders across multiple departments have contributed requirements for this workstream. Service-level indicators are collected continuously and aggregated into dashboards visible to both technical teams and business stakeholders. The operational acceptance criteria include automated smoke tests, performance baselines, runbook completeness, and sign-off from both the IT Service Manager and the business process owner. The security monitoring SIEM has been a critical area of focus for ArchiSurance since the digital transformation initiative began in 2023. The Architecture Review Board convened a special session in February 2025 to evaluate the implications of the proposed changes on downstream systems and business processes. Deployment windows are scheduled every Tuesday and Thursday between 06:00 and 08:00 CET, with emergency deployments requiring approval from both the IT Service Manager and the on-call engineer. External consultants from Deloitte provided an independent assessment of the architecture in late 2024. Key performance indicators for the initiative include transaction throughput, error rate, mean time to detection, mean time to recovery, and user satisfaction scores collected through quarterly surveys. Change management activities include stakeholder communication, training sessions, and documentation updates. The observability strategy follows the three pillars model: structured logs shipped to Elasticsearch, distributed traces collected via OpenTelemetry, and metrics scraped by Prometheus; all three are unified in Grafana dashboards.

A proof-of-concept was conducted over a four-week period, involving representatives from the Claims Department, IT Operations, and the Data Analytics Team to validate the technical feasibility. The architectural principles that guide this work include separation of concerns, loose coupling between components, preference for open standards, and the ability to scale horizontally under peak load conditions such as end-of-year policy renewals. Budget allocation was approved as part of the annual IT investment portfolio review conducted in November 2024. The architecture decisions were reviewed and approved by the Architecture Review Board in Q2 2024. Automated deployment pipelines leverage the CI/CD infrastructure described in the platform engineering documentation. Application health is assessed using a

synthetic monitoring approach, where automated scripts simulate real user journeys every five minutes and report availability from three geographically distributed probe locations. Security review was completed in accordance with the CISO's security-by-design framework. The network team conducted a bandwidth utilization study in February 2025, confirming that inter-datacenter traffic remains below sixty percent of the available WAN capacity under normal operating conditions. Compliance with the General Data Protection Regulation requires that personally identifiable information is encrypted at rest and in transit, with access restricted to authorized roles as defined in the Identity and Access Management policy. The operational support model is defined in the Operational Runbook and includes on-call rotation and escalation procedures.

Feedback from the user acceptance testing phase indicated that the new interface reduced the average task completion time by approximately thirty percent compared to the legacy system, though some users requested additional keyboard shortcuts for power-user workflows. The migration strategy follows a strangler-fig pattern, where new functionality is built in the target platform while legacy features are gradually redirected; this approach minimizes disruption to active users and allows incremental validation of the new implementation. Application health is assessed using a synthetic monitoring approach, where automated scripts simulate real user journeys every five minutes and report availability from three geographically distributed probe locations. External consultants from Deloitte provided an independent assessment of the architecture in late 2024. The enterprise data model, maintained by the Data Architecture team, defines canonical schemas for all shared data objects; integrating systems are expected to conform to these schemas or implement transformation layers that map proprietary formats to the canonical model. The enterprise architecture repository in Sparx EA is the authoritative source for all model elements; any changes to this document must be reflected there within five business days. The architectural principles that guide this work include separation of concerns, loose coupling between components, preference for open standards, and the ability to scale horizontally under peak load conditions such as end-of-year policy renewals. The vendor selection process followed the procurement guidelines established by the CFO's office. During the initial assessment phase, the team identified several areas where the existing architecture fell short of the target-state requirements defined in the enterprise roadmap. Documentation standards require that all architecture decisions are recorded as Architecture Decision Records using the ADR format proposed by Michael Nygard, stored alongside the codebase in the version control system.

A chaos engineering program was introduced in Q1 2025, starting with controlled fault injection in the staging environment to validate the resilience of the system against network partitions and dependency failures. From a historical perspective, ArchiSurance first recognized the need for modernization in this area following an internal efficiency review conducted in late 2022, which highlighted significant manual effort and process duplication across regional offices. A proof-of-concept was conducted over a four-week period, involving representatives from the Claims Department, IT Operations, and the Data Analytics Team to validate the technical feasibility. The business process documentation follows the BPMN 2.0 standard, with process models maintained in the Signavio process modeling tool and linked to the ArchiMate model elements in Sparx EA. The solution leverages event-driven patterns wherever possible, with Apache Kafka providing durable, ordered event streams that decouple producers from consumers and enable replay for debugging and reprocessing scenarios. The project governance structure includes a steering committee meeting monthly, a working group meeting weekly, and daily stand-ups during active development sprints. Cost allocation for shared infrastructure follows a chargeback model based on resource consumption metrics, with monthly reports sent to each business unit for transparency and accountability. The architecture team conducted a threat modeling exercise using the STRIDE framework, identifying potential spoofing, tampering, and information disclosure risks; mitigations for each threat were documented and tracked in the security risk register. Regression test suites are maintained by the QA team and executed automatically on every merge to the main branch via the CI/CD pipeline. A dedicated Slack channel was established for real-time coordination between development, operations, and security teams during the rollout period.

6. Compliance Requirements

GDPR Compliance

The GDPR Compliance requirement is a mandatory architectural constraint. Implementation details are documented in the Compliance and Regulatory Requirements document (EA-CMP-016).

Data privacy impact assessment was filed with the Data Protection Officer in Q1 2025. A proof-of-concept was conducted over a four-week period, involving representatives from the Claims Department, IT Operations, and the Data Analytics Team to validate the technical feasibility. The GDPR Compliance has been a critical area of focus for ArchiSurance since the digital transformation initiative began in 2023. The vendor risk assessment framework evaluates suppliers across five dimensions: financial stability, technology roadmap alignment, support quality, security posture, and contractual flexibility.

PCI-DSS Level 1 Certification

The PCI-DSS Level 1 Certification requirement is a mandatory architectural constraint. Implementation details are documented in the Compliance and Regulatory Requirements document (EA-CMP-016).

The migration strategy follows a strangler-fig pattern, where new functionality is built in the target platform while legacy features are gradually redirected; this approach minimizes disruption to active users and allows incremental validation of the new implementation. A formal lessons-learned workshop is held at the end of each quarter, with outcomes published to the internal wiki and action items assigned to specific team members with target completion dates. Risk mitigation strategies include regular checkpoint reviews, automated regression testing, and staged rollout procedures. The total cost of ownership analysis, prepared by the Finance Department in collaboration with IT, indicated a payback period of approximately eighteen months assuming current utilization rates.

SOX Audit Trail

The SOX Audit Trail requirement is a mandatory architectural constraint. Implementation details are documented in the Compliance and Regulatory Requirements document (EA-CMP-016).

Cost allocation for shared infrastructure follows a chargeback model based on resource consumption metrics, with monthly reports sent to each business unit for transparency and accountability. From a historical perspective, ArchiSurance first recognized the need for modernization in this area following an internal efficiency review conducted in late 2022, which highlighted significant manual effort and process duplication across regional offices. The incident management process defines four severity levels, with Severity 1 incidents requiring a response within fifteen minutes and a post-incident review within five business days. The project governance structure includes a steering committee meeting monthly, a working group meeting weekly, and daily stand-ups during active development sprints.

Role-based Access Control

The Role-based Access Control requirement is a mandatory architectural constraint. Implementation details are documented in the Compliance and Regulatory Requirements document (EA-CMP-016).

A formal lessons-learned workshop is held at the end of each quarter, with outcomes published to the internal wiki and action items assigned to specific team members with target completion dates. The initiative is tracked in the enterprise PMO tool with bi-weekly status updates to the steering committee. The architecture review confirmed that the proposed solution aligns with the TOGAF Architecture Development Method phases used by ArchiSurance, specifically phases B through D covering Business, Information Systems, and Technology Architecture. Automated deployment pipelines leverage the CI/CD infrastructure described in the platform engineering documentation.

Data Encryption at Rest and in Transit

The Data Encryption at Rest and in Transit requirement is a mandatory architectural constraint. Implementation details are documented in the Compliance and Regulatory Requirements document (EA-CMP-016).

Collaboration with the vendor support team has been essential during the implementation phase; weekly technical syncs ensure that configuration changes are validated against the vendor's reference architecture before being applied to the production environment. The operational support model is defined in the Operational Runbook and includes on-call rotation and escalation procedures. The operational acceptance criteria include automated smoke tests, performance baselines, runbook completeness, and sign-off from both the IT Service Manager and the business process owner. Business continuity considerations were incorporated from the outset, with the DR Recovery Node in the secondary data

center providing failover capacity; the most recent failover test was conducted in October 2024 and achieved recovery within the target RTO of one hour.

The overarching goal is to Achieve Full Regulatory Compliance. The constraint 'No Public Cloud for PII Data (until 2026 review)' limits deployment options for systems handling personally identifiable information.

7. Security Architecture Decisions

ADR ID	Decision	Status	Date
SEC-001	Use HSM for all key mgmt	Accepted	2024-03
SEC-002	Enforce TLS 1.3 only	Accepted	2024-05
SEC-003	MFA for all internal users	Accepted	2024-07
SEC-004	Zero-trust network model	Proposed	2025-01
SEC-005	SIEM migration to cloud	Under Review	2025-03

The Architecture Review Board convened a special session in February 2025 to evaluate the implications of the proposed changes on downstream systems and business processes. Lessons learned from the pilot phase have been incorporated into the current design iteration. Collaboration with the vendor support team has been essential during the implementation phase; weekly technical syncs ensure that configuration changes are validated against the vendor's reference architecture before being applied to the production environment. Scalability testing performed in the staging environment confirmed that the system handles a three-times-peak load without degradation, providing sufficient headroom for seasonal demand fluctuations. Stakeholders across multiple departments have contributed requirements for this workstream. Service-level indicators are collected continuously and aggregated into dashboards visible to both technical teams and business stakeholders. The solution was designed to be modular, allowing individual components to be upgraded or replaced without affecting the overall system availability or data integrity. Post-implementation review sessions are scheduled for thirty and ninety days after go-live to capture lessons learned and identify optimization opportunities. Change management activities include stakeholder communication, training sessions, and documentation updates.

Business continuity considerations were incorporated from the outset, with the DR Recovery Node in the secondary data center providing failover capacity; the most recent failover test was conducted in October 2024 and achieved recovery within the target RTO of one hour. The architecture team maintains a dependency register that maps each component to its upstream providers and downstream consumers, updated quarterly. The initiative is tracked in the enterprise PMO tool with bi-weekly status updates to the steering committee. The security architecture decisions ADR has been a critical area of focus for ArchiSurance since the digital transformation initiative began in 2023. Cross-functional workshops held in January and March 2025 helped refine the scope and integration points. Interoperability with partner systems is achieved through the Partner Integration Hub, which exposes a curated subset of the internal API surface with additional rate limiting, schema validation, and audit logging applied at the gateway layer. The team uses a definition of done that includes code review by at least two peers, passing CI pipeline, updated architecture diagrams, and entry in the change log maintained by the Release Manager. Technical debt in this area was cataloged during a dedicated sprint in Q3 2024; the resulting backlog of forty-seven items has been prioritized by business impact and is being addressed alongside feature development. The Architecture Review Board convened a special session in February 2025 to evaluate the implications of the proposed changes on downstream systems and business processes.

The enterprise technology radar, published semi-annually by the CTO's office, classifies technologies as Adopt, Trial, Assess, or Hold; the technologies used in this area are all currently in the Adopt or Trial rings. The architecture review confirmed that the proposed solution aligns with the TOGAF Architecture Development Method phases used by ArchiSurance, specifically phases B through D covering Business, Information Systems, and Technology Architecture. The architecture team conducted a threat modeling exercise using the STRIDE framework, identifying potential spoofing, tampering, and information disclosure risks; mitigations for each threat were documented and tracked in the security risk register. Business continuity considerations were incorporated from the outset, with the DR Recovery Node in the secondary data center providing failover capacity; the most recent failover test was conducted in October 2024 and achieved recovery within the target RTO of one hour. The API design guidelines specify that all REST endpoints

must support content negotiation, return standard HTTP status codes, include correlation identifiers in response headers, and provide machine-readable error bodies in RFC 7807 format. Cost allocation for shared infrastructure follows a chargeback model based on resource consumption metrics, with monthly reports sent to each business unit for transparency and accountability. External consultants from Deloitte provided an independent assessment of the architecture in late 2024. Capacity forecasting models project a twenty-five percent year-over-year increase in data volume, driven primarily by the digitization of paper-based processes and the expansion of the broker channel. The project governance structure includes a steering committee meeting monthly, a working group meeting weekly, and daily stand-ups during active development sprints.

8. Appendices

References and Related Documents

Doc ID	Title	Version
EA-OVR-001	Enterprise Architecture Overview	3.0
EA-APP-002	Application Portfolio & Inventory	4.2
EA-INFRA-003	Infrastructure Design Document	2.5
EA-BIZ-004	CRM Business Process Description	2.0
EA-CLM-005	Claims Processing Workflow	3.1
EA-SEC-006	Security Architecture	2.3
EA-INT-007	Integration Architecture	2.8
EA-DAT-008	Data Architecture & Governance	2.0
EA-CLD-009	Cloud Migration Assessment	1.5
EA-DR-010	Disaster Recovery & Business Contin	3.0
EA-NET-011	Network Architecture	2.2
EA-ROAD-012	Strategic IT Roadmap 2025-2027	2.0
EA-SVC-013	IT Service Catalog	3.5
EA-VND-014	Vendor & Technology Assessment	1.8
EA-OPS-015	Operational Runbook: Core Platform	4.1
EA-CMP-016	Compliance & Regulatory Requirement	2.5
EA-CHG-017	Change Management: ERP Migration	1.2

Distribution List

Name	Role	Responsibility
J. van den Berg	Enterprise Architect	Review & Approve
M. de Vries	Application Architect	Review & Contribute
P. Jansen	Integration Architect	Review & Contribute
K. Bakker	Infrastructure Architect	Review & Contribute
S. Visser	Business Analyst	Inform
T. Mulder	Process Architect	Inform
R. de Jong	CISO	Review & Approve
L. Hendriks	Data Architect	Inform
A. Willems	CTO	Final Approval
B. Smit	Head of Claims	Business Sign-off

Glossary of Acronyms

Acronym	Definition
API	Application Programming Interface
BPM	Business Process Management
CDN	Content Delivery Network
CISO	Chief Information Security Officer
CRM	Customer Relationship Management
DR	Disaster Recovery
DMS	Document Management System
DMZ	Demilitarized Zone
EA	Enterprise Architecture
ESB	Enterprise Service Bus
ETL	Extract, Transform, Load

FNOL	First Notice of Loss
GDPR	General Data Protection Regulation
HSM	Hardware Security Module
IAM	Identity and Access Management
KPI	Key Performance Indicator
LAN	Local Area Network
MTTR	Mean Time to Recovery
NPS	Net Promoter Score
PAS	Policy Administration System
PCI-DSS	Payment Card Industry Data Security Standard
PoC	Proof of Concept
RBAC	Role-Based Access Control
RPO	Recovery Point Objective
RTO	Recovery Time Objective
SAN	Storage Area Network
SLA	Service Level Agreement
SOX	Sarbanes-Oxley Act
STP	Straight-Through Processing
VLAN	Virtual Local Area Network
VPN	Virtual Private Network
WAN	Wide Area Network

Appendix: Meeting Minutes - Architecture Review Board

Date: March 15, 2025. Location: ArchiSurance HQ, Room 4.12. Attendees: J. van den Berg (chair), M. de Vries, P. Jansen, K. Bakker, S. Visser, T. Mulder (remote). Apologies: R. de Jong (on leave).

Agenda item 1: Review of open action items from previous meeting. Action 2024-47 (Jansen): Provide updated cost estimate for Oracle migration. Status: Completed. The revised estimate is EUR 1.4M including contingency. Action 2024-48 (de Vries): Schedule penetration test with external vendor. Status: In progress, vendor shortlist reduced to two candidates.

Agenda item 2: Discussion on coffee machine replacement in the 3rd floor kitchen. The current Jura E8 has been experiencing frequent bean grinder failures. Facilities will procure a replacement by end of month. Not related to architecture but raised due to impact on team productivity during long review sessions.

Agenda item 3: Parking lot discussion about whether to adopt Backstage as the internal developer portal. Deferred to next meeting pending PoC results. K. Bakker noted that the onboarding documentation is outdated and should be refreshed regardless of the portal decision.

Next meeting: April 12, 2025 at 14:00 CET. Van den Berg to circulate agenda by April 5.

Detailed Revision Notes for Version 2.1

Section 2.3 was updated to reflect the new naming convention adopted by the Platform Engineering team. All references to 'microservice cluster' have been replaced with 'application workload group' per the Architecture Board decision of January 2025. Section 4.1 was expanded to include the results of the capacity planning exercise conducted in Q4 2024, which identified the need for additional compute resources in the Amsterdam primary data center.

Appendix B was added to include the RACI matrix requested by the PMO during the Q3 2024 quarterly review. The glossary was updated to include twelve new acronyms that were introduced since the previous version. Figure 3 was replaced with an updated diagram generated from the Sparx EA repository on March 28, 2025. The document classification was elevated from 'Internal' to 'Internal - Confidential' following the data classification review of February 2025.

Feedback from the peer review conducted by M. de Vries on March 10, 2025, addressed three items: (1) clarification of the boundary between the DMZ and the application tier, (2) addition of the backup retention policy reference, and (3)

correction of the SLA target for the Claims Handling Service from 99.5% to 99.9% as agreed in the contract amendment of December 2024.

DISCLAIMER: This document has been prepared for internal use by ArchiSurance B.V. The information contained herein is provided on an 'as-is' basis without warranties of any kind, either express or implied. ArchiSurance B.V. shall not be liable for any direct, indirect, incidental, or consequential damages arising from the use of this document. The views expressed herein are those of the Enterprise Architecture team and do not necessarily reflect the official position of the Board of Directors. All trademarks mentioned belong to their respective owners. This document may contain forward-looking statements that involve risks and uncertainties. Actual results may differ materially from those projected. Recipients are advised to seek independent professional advice before acting on any information contained in this document.